Spec sheet: local client (Tally32 Agent)

Features, permissions and risk assessment

Contact	Oliver Timme
Department / workstation	
Mode of operation	Standalone: one display per workstation. The agent runs on the user's own Windows PC under the user's own account
Features	Status display **and appointment booking on the display** (both core features), which needs the Calendars.ReadWrite permission
Information as of	10/2026, agent and firmware version 1.1, based on the source code. Tested on Windows 11.

1. Purpose

Tally32 is a small status display at the workstation (7 or 10.1 inch screen, connected via USB). It shows colleagues and visitors whether the user is **on a call** (ON AIR), **busy** and **free again from when**, or away from the desk. The second core feature is **appointment booking**: if the user is not at the desk, a visitor can book a free slot directly on the display and receives an invitation. The agent is the program on the PC that collects this information and sends it to the display over the USB cable.

No inbound connections, no open port, no data sent to third parties.

2. What the agent does

Function	Source	Data read	Interval
Call detection	Windows registry (HKCU), read only: Windows microphone usage indicator (CapabilityAccessManager, ConsentStore microphone)	only whether an app is currently using the microphone and which one (e.g. Teams, 3CX). **No audio data.**	2 s
Screen lock	Windows API WTSQuerySessionInformation	only locked yes or no	2 s
Teams status	Microsoft Graph GET /me/presence	availability and activity (e.g. Busy, InACall)	10 s
Calendar	Microsoft Graph GET /me/calendarView, today and tomorrow	only **start, end, free/busy status, cancelled** (field selection $select=showAs,start,end,isCancelled,isAllDay). No subject, no location, no attendees, no body.	60 s
Appointment booking (core feature)	Microsoft Graph GET /me/calendarView (2 weeks) and POST /me/events	reads the same time fields. On request from the display, creates an appointment in the user's own calendar with the title and email address entered by the visitor. Exchange then sends the invitation to the visitor.	only when booking
Output to display	USB serial (COM port, 115200 baud)	status, time, "free from" or "free until", appointment blocks for today and tomorrow (times only), account name	2 to 30 s

3. What the agent does not do

- **No audio or video recording.** It opens neither microphone nor camera. It only reads the Windows indicator showing whether they are in use.
- **Reads no emails, contacts, files or chats** and no subjects, locations, attendees or bodies of appointments.
- **Own mailbox only** (/me). No access to other people's calendars or status.
- **No inbound connections**, no open port, no web server on the PC.
- **Outbound only** to login.microsoftonline.com and graph.microsoft.com (HTTPS 443). No telemetry, no data sent to third parties or to the developer.
- **No administrator rights**, no Windows service, no custom drivers, no changes to system or security settings.
- **No keyboard or screen recording**, no remote control.
- **Executes nothing that comes from the display.** It understands only four fixed text messages: start sign-in, query free slots, book appointment, log line. Everything else is ignored.
- **The display only shows up as a COM port.** Windows sees a COM port and the JTAG debug interface of the display chip, no keyboard (HID) and no mass storage. In principle the display chip (ESP32-P4) could also act as a different USB device on this port (USB OTG). The Tally32 firmware does not enable this.

4. Technical details

Item	Details
Program	Python script agent/tally_agent.py (source code available), Python 3.11 or newer. Can also be packaged as a single .exe (PyInstaller) if Python is not allowed.
Dependencies	msal and msal-extensions (Microsoft Authentication Library, by Microsoft) and pyserial, from PyPI. msal pulls in requests, cryptography and PyJWT. All versions are pinned in agent/requirements.txt (e.g. msal==1.39.0).
Execution	in the user context, hidden (pythonw.exe), started by Task Scheduler "at log on", task "Tally32 Agent". Set up with install_windows.ps1 without elevated rights.
Files	Program and Python environment in the project folder. Settings in %USERPROFILE%\.config\tally32\config.json. Sign-in token **encrypted with Windows DPAPI** in token_cache.bin next to it, readable only under the user's own account (macOS: Keychain). A token from an older version is migrated at startup and the unencrypted file is deleted. Log in %LOCALAPPDATA%\tally32\tally32.log (status changes and bookings with date, time, email address and title entered by the visitor).
USB device	GUITION JC1060P470C 7" or GUITION JC8012P4A1C 10.1" (both ESP32-P4), built-in USB interface of the chip (USB Serial/JTAG, USB VID 303A, PID 1001): COM port and JTAG debug interface of the display. Driver included in Windows.
Network	outbound HTTPS 443 to login.microsoftonline.com and graph.microsoft.com. During setup, pypi.org once for the packages (not needed with the .exe).
Load	very low: about 7 small HTTPS requests per minute, a few MB of RAM.

5. Permissions in Microsoft 365

Permission (delegated)	Purpose	Required
Calendars.ReadBasic	Free/busy times of the user's own calendar. Least privileged read permission for calendarView according to Microsoft. It exposes no appointment text and no attachments. The agent only requests the time fields. No admin consent required.	yes
Presence.Read	own Teams status	optional (can be disabled)
Calendars.ReadWrite	Appointment booking on the display: create an appointment in the user's own calendar with an invitation to the visitor. Core feature, enabled in the agent ("booking": true).	yes

Sign-in uses the device code flow with the user's own account, delegated, so never more rights than the user has. By default it uses the public Microsoft client "Microsoft Graph Command Line Tools" (app ID 14d82eec-204b-4c2f-b7e8-296a70dab67e). If IT prefers, a dedicated app registration in the tenant can be used instead (only the app ID changes). This needs admin consent once (section 10).

6. The display

- stores **no Microsoft token** and no calendar content, only the appointment blocks for today and tomorrow (times without text, valid for at most 16 hours), so it keeps working when undocked.
- opens its **own Wi-Fi** for setup (Tally32-XXXX, WPA2 with password) with a password-protected web interface. This Wi-Fi has no connection to the company network and no internet. It stores only settings, the Wi-Fi password and the hash of the web password. The setup Wi-Fi can be **turned off** in the web interface or in the menu on the display. It can only be

turned back on at the device itself (settings menu with PIN or pressing the display for 5 seconds).
- shows only status and times at the desk, **never subjects** of appointments.

7. Risk assessment

Risk	Likelihood	Impact	Controls	Residual
Malware running under the user account reads the sign-in token	low	medium: own calendar readable, with booking also writable, until revoked	Token encrypted with Windows DPAPI (readable only under the user's own account), delegated rights only, can be revoked in Entra at any time. Write access to the user's own calendar only, every booking traceable in the agent log.	low
Misuse of booking on the display (unwanted appointments or invitations)	medium	low	only free slots within the configured time window, at most 4 bookings per hour, invitation only to the address entered. Time window, weekdays and lunch break set in setup. Every booking appears in the calendar and in the log. The feature can be turned off on the display if needed.	low
Additional Wi-Fi in the office from the display	certain	low	WPA2 with its own password, no routing into the company network, web interface with password and mandatory password change. Setup Wi-Fi can be turned off in the web interface and turned back on only at the device.	low
Tampered display or USB device	low	low	Agent accepts only four fixed text messages, no code execution. The display only shows up as a COM port and JTAG interface, no keyboard. Different firmware could change this, but that requires physical access to the display.	low
Dependencies from PyPI (supply chain)	low	medium	only three widely used packages (msal and msal-extensions by Microsoft, pyserial). All versions including indirect packages pinned, optionally a reviewed .exe.	low
Sign-in via device code (known phishing pattern)	low	low	Only the user starts the sign-in, and the token ends up on the user's own PC. If Conditional Access blocks the device code flow, a dedicated app registration is needed.	low
Privacy: availability visible at the desk	intended	low	only status and times, no subjects, same as the Teams status. The screensaver shows only the logo.	low

Overall assessment: low risk. The agent works with the user's rights, reads only times and status of the user's own account, opens no ports and talks only to Microsoft. It writes only for appointment booking and only to the user's own calendar. The token is stored encrypted in the user profile.

8. Safeguards and operating notes

- Store the sign-in token encrypted (Windows DPAPI). *Implemented.*
- Pin package versions (agent/requirements.txt). *Implemented.*
- Give the display's setup Wi-Fi its own password and turn it off after setup (web interface, setup Wi-Fi section). *Implemented.*
- Optionally use a dedicated app registration in the tenant instead of the public Microsoft client.
- If USB device control is in place, allow only the device VID 303A / PID 1001, and for it only the classes COM port (CDC) and JTAG, no keyboard (HID).

9. Revocation and uninstall

- Delete sign-in: `tally_agent.py logout` (deletes the stored token).
- Block access on the server side: revoke the user's sign-in sessions in Entra or remove the consent for the app.
- Remove: `install_windows.ps1 -Uninstall` (task and process), then delete the project folder and %USERPROFILE%\.config\tally32.

10. Why admin consent is needed once

The agent needs **no admin rights** on the PC. However, **consent in Microsoft Entra ID** is needed once, so that the agent may access the user's own calendar and Teams status on the user's behalf.

What	Admin consent for the app "Microsoft Graph Command Line Tools" (or a dedicated app registration) with the delegated permissions Calendars.ReadBasic, Calendars.ReadWrite and Presence.Read
Why	Many tenants do not let users consent to apps themselves, and write access to the calendar is usually granted only by an admin. Without consent, sign-in fails with "Need admin approval".
How often	once. After that the user signs in, and the agent renews its tokens without further approval.
What it does not mean	no admin rights on the PC, no access to other mailboxes (delegated, own account only), no application permission (app-only), no access to emails, files or chats
Limit scope	Consent can be limited to this one user instead of the whole organization (OAuth2 permission grant with consentType Principal, see below). Alternatively, a dedicated app registration assigned only to this user.
Undo	remove the permission in Entra under Enterprise applications, takes effect immediately

Consent for one user only (Microsoft Graph PowerShell, replace the placeholders):

```
New-MgOauth2PermissionGrant -BodyParameter @{
  clientId    = "<object ID of the app's service principal>"
  consentType = "Principal"
  principalId = "<object ID of the user>"
  resourceId  = "<object ID of the Microsoft Graph service principal>"
  scope       = "Calendars.ReadBasic Calendars.ReadWrite Presence.Read"
}
```

11. At a glance

Item	Details
Program	Tally32 Agent, Python script, runs under the user's own account without admin rights
Reads	own Teams status, times and free/busy of the own calendar, whether the microphone is in use, whether the screen is locked
Does not read	emails, files, chats, contacts, subjects, attendees and bodies of appointments, audio
Writes	appointment booking (core feature): appointments in the own calendar with invitation to the visitor
Network	outbound HTTPS only to login.microsoftonline.com and graph.microsoft.com, no open port
Microsoft 365 permissions	delegated: Calendars.ReadBasic, Calendars.ReadWrite (appointment booking), Presence.Read, one-time admin consent
Device	display via USB (only COM port and JTAG of the display), own setup Wi-Fi with WPA2, can be turned off
Overall risk	**low** (section 7)
Revocation	at any time: delete token, revoke sessions in Entra, remove scheduled task